Rapport d’audit



Rapport d’audit 1
Contexte et périmètre 2
Fonctionnalités 3
Acteurs 3
Fonctionnalités du gestionnaire LiVrai 3
Fonctionnalités du client 3
Cycle de vie d’une commande 3
Expérience utilisateur 5
Méthode 5
Parcours principaux 5
Constats 6
Synthèse 8
Description technique 9
Schémas d'architecture 9
Points forts 10
Conclusion 13

Contexte et périmètre

LiVrai est une entreprise de livraison B2B en forte croissance, tant en nombre de clients qu'en volume de commandes. Pour gérer ses clients et leurs commandes, elle s'appuie sur un CRM interne développé en Java EE / JSP, qui montre aujourd'hui ses limites face à cette montée en charge. Les utilisateurs constatent des lenteurs, les équipes techniques rencontrent des difficultés de maintenance, et l'entreprise s'inquiète de la disponibilité du service lors des pics d'activité.

Avant d'engager une refonte, Meilin, cheffe de projet responsable du CRM, souhaite disposer d'un état des lieux objectif de l'application existante. C'est l'objet de cet audit. Il décrira d'abord les fonctionnalités proposées, les types d'utilisateurs concernés et l'expérience qu'ils en ont. Il analysera ensuite la conception technique de l'application, de ses différentes couches jusqu'à sa base de données. Enfin, il dégagera les principaux points forts et les limites de la solution, en particulier au regard de la volumétrie croissante et des exigences de disponibilité.

L'audit porte sur le code source de l'application tel qu'il figure dans son dépôt, ainsi que sur son utilisation après déploiement dans un environnement local conteneurisé avec Docker. Il couvre les aspects fonctionnels, l'expérience utilisateur, l'architecture technique et la base de données. Enfin, cet audit se limite volontairement au constat. Les choix de refonte feront l'objet d'un travail distinct, qui s'appuiera sur ses conclusions.

Fonctionnalités

Acteurs

L'application distingue deux types d'utilisateurs.

Le gestionnaire LiVrai. Employé de LiVrai disposant d'un compte administrateur, il gère la relation avec les clients et le traitement de leurs commandes.

Le client. Entreprise cliente de LiVrai, elle utilise le CRM pour commander des livraisons et en suivre l'avancement. Elle ne peut pas créer son compte elle-même, celui-ci lui est fourni par LiVrai.

Fonctionnalités du gestionnaire LiVrai

- S'authentifier sur l'application.
- Créer un compte client.
- Consulter les commandes passées par les clients.
- Traiter une commande, en l'acceptant et en fixant son prix, ou en la refusant.

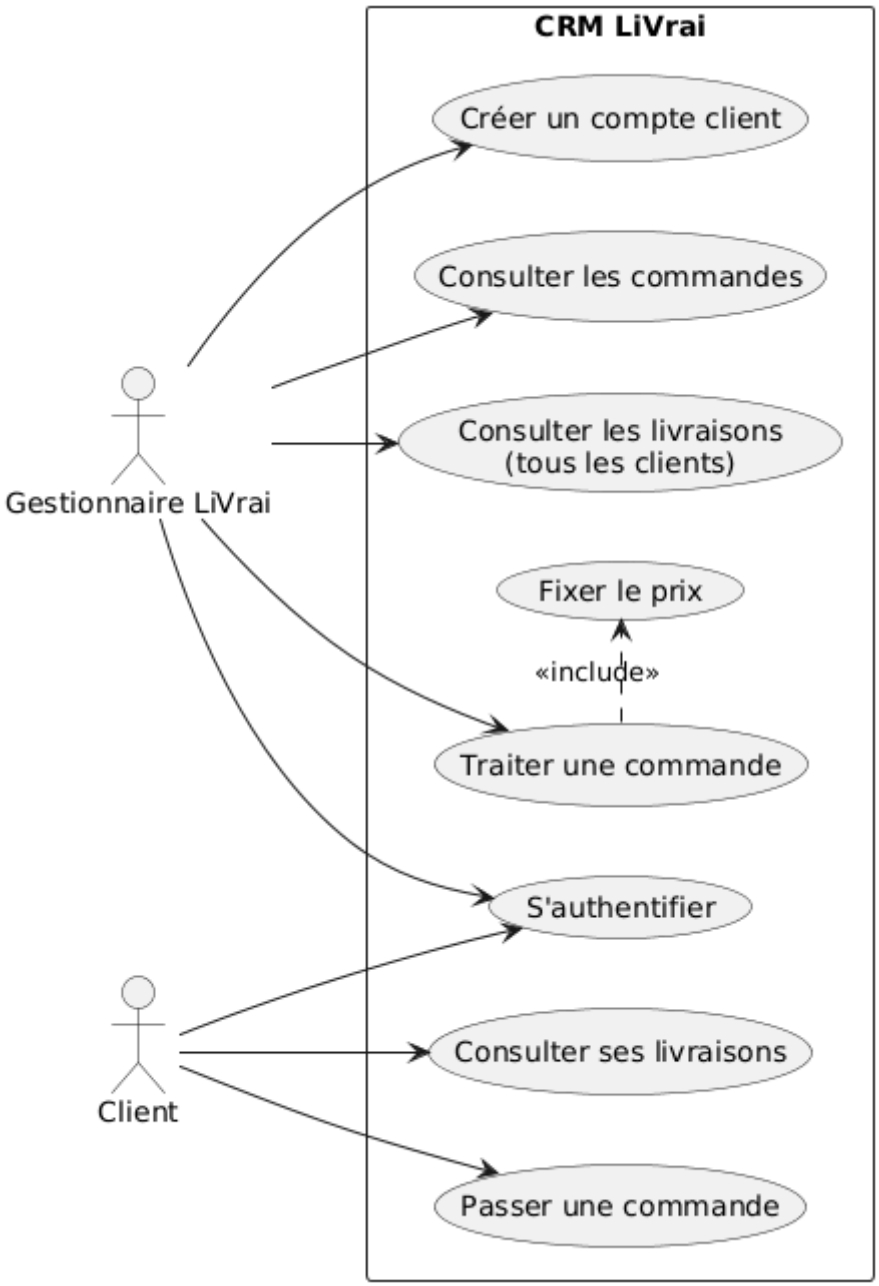
Fonctionnalités du client

- S'authentifier avec le compte fourni par LiVrai.
- Passer une commande de livraison.
- Consulter ses commandes passées et traitées.

Cycle de vie d'une commande

Une commande est créée par le client, puis examinée par un gestionnaire LiVrai, qui l'accepte en fixant son prix ou la refuse. Une commande passée devient une livraison à venir, puis une livraison passée une fois acceptée.

Il semblerais que ce logiciel fasse le pont entre le service de gestion des stocks et celui de gestion des commandes/facturation.


CRM LiVrai
Créer un compte client
Consulter les commandes
Consulter les livraisons
(tous les clients)
Fixer le prix
«include»
Traiter une commande
S'authentifier
Consulter ses livraisons
Passer une commande
Gestionnaire LiVrai
Client

Expérience utilisateur

Méthode

L'application a été parcourue en se plaçant successivement dans le rôle d'un gestionnaire LiVrai puis d'un client, sur un navigateur desktop, avec un jeu de données de quelques dizaines d'enregistrements. L'usage sur mobile et tablette n'a pas été évalué. Les constats sont rattachés aux critères ergonomiques de Bastien et Scapin, une grille d'évaluation reconnue.

Parcours principaux

Passer une commande et en suivre l'état (client). Le client se connecte avec les identifiants transmis par le gestionnaire LiVrai. Il arrive sur une page vide, qui ne contient qu'une barre de navigation et un message de bienvenue, et doit deviner que l'intitulé "Commande" est un lien. Celui-ci ouvre un formulaire intitulé "Nouvelle livraison", qui ne comporte que deux champs, volume et poids, sans unité ni explication. Après envoi, aucune confirmation n'est affichée. Le client doit se rendre dans l'onglet "Livraisons" pour constater que sa commande apparaît dans "Mes livraisons à venir", avec le statut "en attente". Une fois la commande acceptée par LiVrai, elle passe dans "Mes livraisons passées", où une colonne prix apparaît sans qu'il soit précisé à quoi correspond ce montant. On ne peux voir ce qui se passe quand une commande est refusée (voir section suivante)

Créer un client et traiter une commande (gestionnaire). Le gestionnaire se connecte avec ses identifiants administrateur et arrive sur la même page d'accueil vide. L'onglet "Clients" présente la liste des clients et un formulaire de création de compte. Aucun écran ne permet de modifier ou de supprimer un compte existant. L'onglet "Livraisons" liste les commandes à venir, que le gestionnaire peut accepter ou refuser. Une fois la commande acceptée, il peut saisir un montant à facturer dans un champ dont rien n'indique qu'il s'agit du prix. Si la commande est refusée il obtiens une page d'erreur 405.

Constats

Un guidage insuffisant. La page d'accueil ne propose aucun point d'entrée vers les tâches principales, et les onglets se distinguent peu visuellement de simples titres. Les formulaires ne précisent pas systématiquement ni l'objet des champs ni leurs unités (volume, poids, prix). Aucune confirmation n'est affichée après l'envoi d'une commande, si bien que le client ne sait pas si sa demande a été prise en compte. Ces manques allongent la prise en main et augmentent le risque d'erreur de saisie, en particulier pour les clients, qui utilisent l'application ponctuellement. En cas de saisie invalide, blocage front, mais pas de validation serveur : si on bypass le front, on obtiens une 500.

Un vocabulaire et une logique peu cohérents avec le métier. L'onglet "Commande" ouvre un formulaire "Nouvelle livraison", et les deux notions sont employées indifféremment. Les tableaux affichent un identifiant technique, qui n'a pas de sens pour l'utilisateur, mais aucune référence de commande ou de client exploitable, par exemple lors d'un échange avec le service client. Surtout, une commande simplement acceptée et facturée est classée dans les livraisons "passées" alors qu'elle n'a pas nécessairement encore été livrée. Le client n'a donc aucun moyen de distinguer une livraison planifiée d'une livraison effectuée.

Des anomalies d'affichage dans les tableaux. Dans la liste des livraisons passées, une colonne manque. Le prix s'affiche à la suite du poids, le statut dans la colonne prix, et la colonne statut reste vide. Côté gestionnaire, les en-têtes de colonnes ne sont pas alignés avec les données. Ces anomalies rendent les informations difficiles à interpréter, voire trompeuses, et laissent supposer un manque de tests sur l'interface.

Des listes inadaptées à la volumétrie. Les listes de clients et de commandes ne proposent ni pagination, ni filtre, ni recherche. Avec une vingtaine d'entrées, elles restent lisibles. Avec plusieurs centaines, ce qui correspond à la trajectoire de croissance de LiVrai, retrouver un client ou une commande précise devient très laborieux.

Une gestion des comptes entièrement manuelle. Le client ne peut ni créer ni modifier son compte. Le gestionnaire doit donc créer chaque compte et

transmettre lui-même les identifiants, une charge qui augmente avec chaque nouveau client. Ces nombreuses opérations manuelles multiplient les risques d'erreur, comme l'envoi d'identifiants au mauvais destinataire. De plus, le client ne pouvant pas changer son mot de passe, celui-ci reste connu du gestionnaire qui l'a défini. Enfin, en l'absence d'écran de modification ou de suppression, toute correction d'un compte client nécessite une intervention directe en base de données.

Parcours concerné	**Constat**	**Critère (Bastien et Scapin)**	**Impact pour LiVrai**	**Gravité**
Tous	Page d'accueil vide, onglets peu identifiables, champs sans unité ni explication	Guidage (incitation, lisibilité)	Prise en main longue, erreurs de saisie	Moyenne
Commande (client)	Aucune confirmation après envoi	Guidage (feedback immédiat)	Incertitude du client, doublons ou sollicitations du support	Moyenne
Suivi des livraisons	Commande facturée classée en livraison passée, terminologie commande et livraison mélangée	Homogénéité, compatibilité	Suivi des livraisons impossible pour le client	Élevée
Suivi des livraisons	Colonnes décalées, prix et statut mal affichés	Guidage (lisibilité)	Informations erronées, perte de confiance	Élevée
Gestion clients et commandes	Ni pagination, ni filtre, ni recherche	Charge de travail	Écrans inexploitables avec la croissance	Élevée
Gestion des comptes	Création manuelle, pas de modification ni de suppression, mot de passe connu du gestionnaire	Contrôle explicite	Charge croissante pour le gestionnaire, risques d'erreur et de sécurité	Élevée

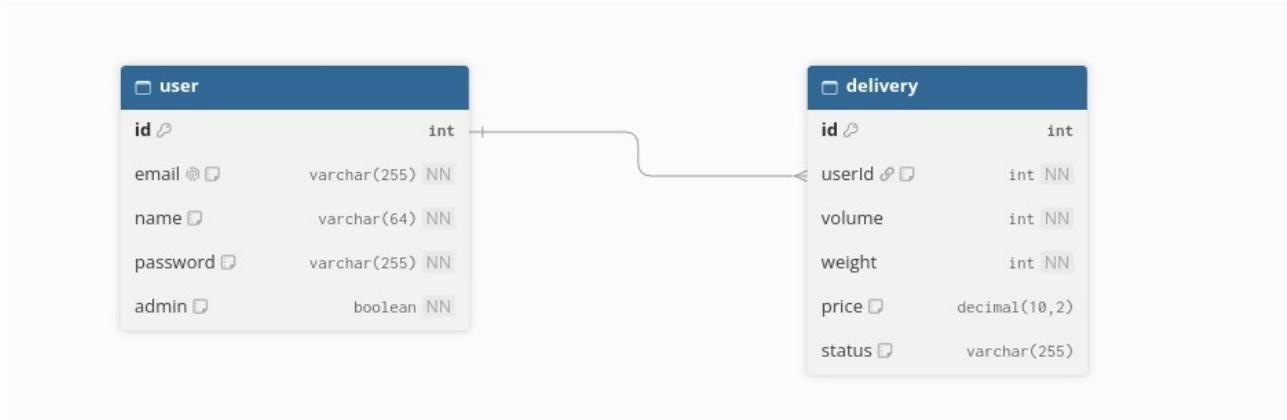
Synthèse

Le périmètre fonctionnel de l'application est restreint et correspond bien au besoin de base, ce qui rend les parcours courts. Malgré le manque de guidage, un utilisateur finit par comprendre ce que l'application permet de faire. En revanche, plusieurs défauts dépassent le simple confort d'utilisation. Les anomalies d'affichage et la confusion entre livraisons à venir et passées faussent l'information transmise au client. L'absence d'outils de navigation dans les listes et la gestion entièrement manuelle des comptes, peu gênantes avec quelques dizaines de clients, deviendront bloquantes à mesure que leur nombre augmentera. Ces points seront repris dans l'analyse critique.

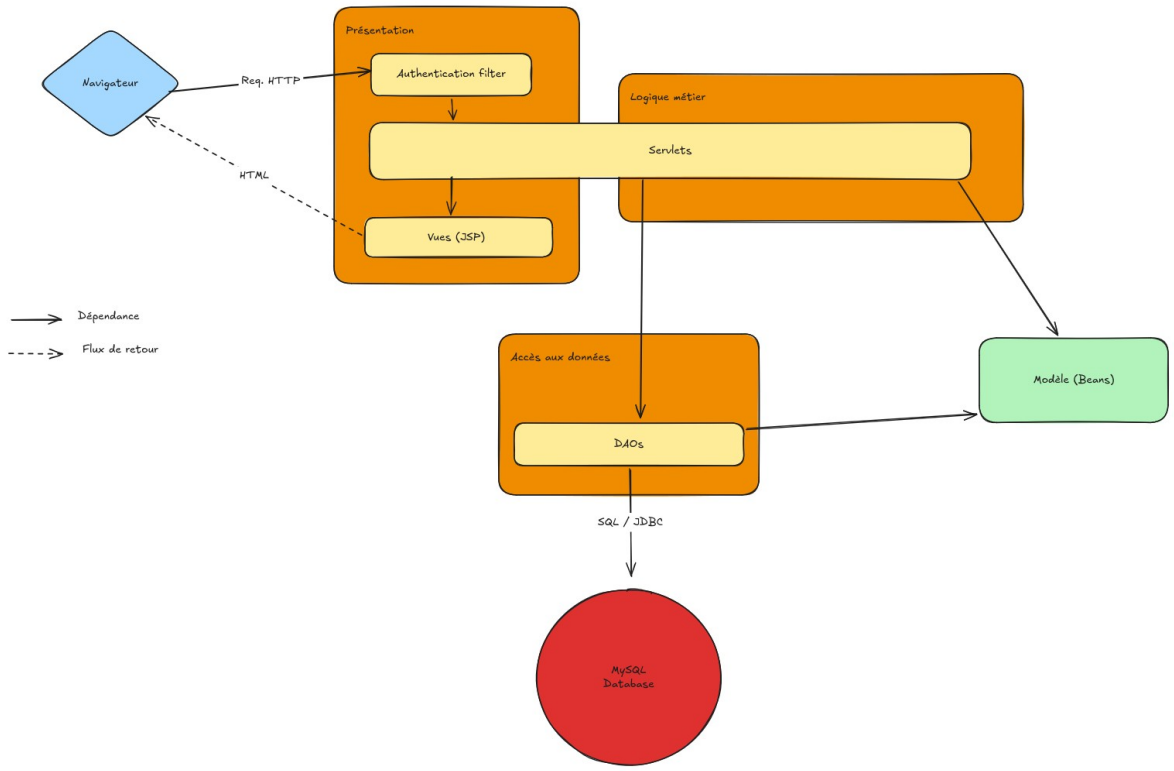
Description technique

Schémas d'architecture

BDD



Architecture



Points forts

Une organisation en couches, même incomplète. L'application sépare l'affichage, l'accès aux données et la représentation des objets métier. Il manque une couche dédiée à la logique métier, mais cette organisation permet d'envisager une évolution progressive, couche par couche, plutôt qu'une réécriture complète d'emblée.

Des fondations de sécurité exploitables. L'accès à la base passe systématiquement par des requêtes paramétrées et les données affichées sont échappées, ce qui protège l'application contre les injections SQL et l'injection de scripts. Par ailleurs, toutes les requêtes transitent par un point d'entrée unique chargé de l'authentification. Il ne gère aujourd'hui aucune autorisation, mais constitue l'emplacement naturel pour la centraliser.

Un modèle de données simple. La base repose sur deux tables reliées par une clé étrangère, ce qui la rend rapide à comprendre. Sa reprise ne sera toutefois pas immédiate. Les mots de passe, stockés en clair, imposeront une réinitialisation de tous les comptes, et les statuts, saisis en texte libre, devront être inventoriés et harmonisés.

Risques et déficiences

Disponibilité et volumétrie, une gestion des connexions qui conduit à la panne. L'application ouvre de nouvelles connexions à la base à chaque requête sans jamais les libérer, et sans pool de connexions pour les mutualiser. Ces connexions s'accumulent jusqu'à atteindre la limite du serveur MySQL, qui refuse alors toute nouvelle connexion et rend le CRM entièrement indisponible. Plus le nombre d'utilisateurs augmente, plus cette panne survient vite, ce qui correspond exactement à la crainte de LiVrai pour les pics d'activité. S'y ajoutent deux limites structurelles. L'application tourne sur une instance unique, sans redondance, et conserve les sessions en mémoire, ce qui empêche d'ajouter simplement un second serveur et déconnecte tous les utilisateurs à chaque redémarrage. Enfin, les listes sont chargées sans pagination ni filtre, ce qui dégradera les temps de réponse à mesure que les données s'accumulent.

Sécurité, un contrôle d'accès incohérent. Les droits ne sont pas vérifiés de

façon centralisée, mais au cas par cas dans certaines fonctionnalités seulement. Conséquence directe, un client connecté peut accéder à la liste complète des clients de LiVrai et créer des comptes, la seule protection étant le masquage du lien dans le menu. Ce défaut constitue un risque de violation de données personnelles au sens du RGPD. D'autres protections font défaut. Les mots de passe sont stockés en clair, les identifiants de la base sont écrits dans le code source et utilisent un compte disposant de tous les droits, et les protections usuelles d'une application web (jetons anti-CSRF, sécurisation de la session et du cookie, HTTPS, validation des saisies, limitation des tentatives de connexion) sont absentes.

Maintenance, un socle obsolète et un code fragile. Le projet cible Java 1.6, une version que les JDK actuels ne savent plus compiler. Il repose sur Tomcat 8.5, qui n'est plus maintenu depuis mars 2024, et sur l'ancienne API javax.servlet, dont l'abandon au profit de jakarta.servlet impose une migration pour toute version récente de Tomcat. La branche MySQL 8.0 est sortie du support Premier en avril 2026, et le pilote de connexion utilisé est déprécié. Ce socle technique obsolète expose a des risques de sécurités car les technologies ne sont pas maintenues dans ce sens. Au-delà du socle, la logique métier est dispersée dans les contrôleurs, sans couche dédiée, et l'absence de tests laisse passer des défauts visibles, comme un bouton de refus de commande qui ne fonctionne pas et une gestion incohérente de l'encodage des caractères, qui corrompt les données saisies avec des accents. Enfin, le modèle de données ne couvre pas le métier de LiVrai. Il ne contient ni adresses de prise en charge et de livraison, ni dates, ni informations sur les entreprises clientes, si bien que toute évolution fonctionnelle passera par une refonte du schéma.

Exploitabilité, des incidents impossibles à diagnostiquer. L'application ne dispose d'aucun système de journalisation ni de gestion centralisée des erreurs. Les erreurs sont soit ignorées, soit affichées brutes à l'utilisateur, ce qui dévoile au passage des informations sur le fonctionnement interne. En production, l'équipe n'a donc aucun moyen fiable de détecter une panne ou d'en comprendre la cause, un manque d'autant plus critique que la gestion des connexions décrite plus haut produit précisément ce type d'incident.

Synthèse

Élément	Type	Enjeu concerné	Criticité
Organisation en couches	Point fort	Maintenance, refonte	
Requêtes paramétrées, point d'entrée unique d'authentification	Point fort	Sécurité, refonte	
Modèle de données simple, reprise à préparer	Point fort	Refonte	
Connexions non libérées, instance unique, absence de pagination	Risque	Disponibilité, volumétrie	Critique
Contrôle d'accès incohérent, protections web absentes	Risque	Sécurité, RGPD	Critique
Socle obsolète, logique dispersée, modèle de données incomplet	Risque	Maintenance	Élevée
Absence de journalisation et de gestion des erreurs	Risque	Exploitabilité	Élevée

Conclusion

Le CRM de LiVrai couvre un besoin simple, la commande de livraisons par les clients et leur traitement par un gestionnaire, à travers des parcours courts. Son organisation en couches et son modèle de données compact forment une base compréhensible, sur laquelle une évolution progressive reste envisageable. L'expérience utilisateur souffre toutefois d'un guidage insuffisant, d'anomalies d'affichage et d'une logique de suivi trompeuse, une commande acceptée étant présentée comme déjà livrée et le refus d'une commande échouant. L'absence de pagination et de recherche, ainsi que la gestion entièrement manuelle des comptes, deviendront bloquantes avec la hausse du nombre de clients. Sur le plan technique, la gestion des connexions conduit à une indisponibilité totale sous charge, le contrôle d'accès expose les données des clients, et le socle obsolète comme l'absence d'outils de diagnostic compliquent la maintenance. En l'état, l'application n'est pas en mesure d'accompagner la croissance de LiVrai, et la refonte devra traiter autant la fiabilité et la sécurité du système que la clarté des parcours pour ses utilisateurs.